

- Erhöhung des Sicherheitsbewusstseins durch klare Prozesse und Schulungen.
- Verbesserung der Geschäftskontinuität durch systematisches Risikomanagement.

11.16 Security by Design

Security by Design ist ein Konzept, bei dem IT-Systeme, Software und Prozesse von Anfang an mit Sicherheitsmechanismen ausgestattet werden. Es basiert auf der Idee, Sicherheitsrisiken proaktiv zu minimieren, anstatt sie nachträglich zu beheben.

Prinzipien

- Minimaler Zugriff (Least Privilege Principle): Benutzer und Prozesse erhalten nur die minimal notwendigen Rechte.
- Standardmäßig sicher (Secure Defaults): Voreinstellungen sollten sicher sein (z. B. starke Passwörter, deaktivierte unsichere Funktionen).
- Fehlertoleranz (Fail-Secure): Systeme sollen auch bei Fehlern sicher bleiben, z. B. durch automatische Sperrmechanismen.
- Trennung von Funktionen (Separation of Duties): Kritische Aktionen erfordern mehrere Berechtigungen oder Bestätigungen.
- Ende-zu-Ende-Verschlüsselung: Schutz der Daten während Speicherung und Übertragung.
- Sichere Entwicklungsmethoden: Secure Coding-Praktiken (z. B. OWASP Top 10 zur Vermeidung von Schwachstellen).

Umsetzung

- Bedrohungsanalysen bereits in der Planungsphase durchführen.
- Sicherheitsmechanismen in den gesamten Software-Development-Lifecycle (SDLC) integrieren.
- Automatisierte Sicherheitstests und regelmäßige Code-Reviews nutzen.
- Security Audits und Penetrationstests durchführen, um Schwachstellen frühzeitig zu erkennen.

Vorteile

- Geringere Kosten für nachträgliche Sicherheitsmaßnahmen.